

MVP сервиса «Память рядом»

Responsive Web / PWA • клиент, исполнитель и операционная команда •
готово к разработке с Claude Code

ПАМЯТЬ РЯДОМ

дистанционный уход • проверенные исполнители • подтверждённый результат

*Vibe coding без спецификации создаёт демо. Спецификация, тесты и
вертикальные срезы создают продукт.*

Версия 1.0 • 21 августа 2026 года

Целевая модель запуска: управляемый сервис, не открытый marketplace
«cloud» трактуется как Claude / Claude Code

Содержание

01	Назначение, цели и границы MVP
02	Роли, термины и продуктовая модель
03	Функциональные требования
04	Процессы, статусы и бизнес-правила
05	Информационная модель и хранение данных
06	API и интеграции
07	Интерфейсы и UX-сценарии
08	Архитектура и рекомендуемый стек
09	Безопасность, персональные данные и соответствие
10	Нефункциональные требования и эксплуатация
11	Тестирование и критерии приёмки
12	Организация разработки в Claude Code
13	План реализации и Definition of Done
14	Приложения: структура репозитория, промпт, решения
15	Источники

01 Назначение, цели и границы MVP

Назначение документа

ТЗ является единым источником требований для product owner, операционной команды, дизайнера, разработчиков и Claude Code. Любое изменение поведения продукта оформляется через задачу, обновление требования/ADR и тест; устное решение не считается спецификацией.

Контекст

MVP автоматизирует управляемый сервис дистанционного ухода за захоронениями в Санкт-Петербурге. Клиент покупает услугу у оператора «Память рядом»; оператор назначает проверенного исполнителя, проверяет отчёт и отвечает за результат. Открытая публикация заказов, конкурирующие ставки и прямые расчёты клиента с исполнителем не входят в первую версию.

Цели продукта

ID	Цель	Измеримый результат MVP
G-01	Снизить тревогу первого заказа	Клиент видит состав услуги, смету, статус и подтверждение результата в одном интерфейсе
G-02	Стабилизировать исполнение	Каждый заказ проходит статусную модель, чек-лист, фото «до/после» и QA
G-03	Сократить ручную диспетчеризацию	Назначение, напоминания, отчёт и история не ведутся в разрозненных чатах
G-04	Собрать данные для экономики	По заказу фиксируются канал, труд, дорога, материалы, выплаты, возвраты и причины отклонений
G-05	Подготовить переход к платформе	Версионирование договоров, профиль партнёра, жалобы, аудит и provider-адаптеры заложены в домен

Критерии успеха пилотной версии

≥90% принято с первого раза без возврата исполнителю	≤7% переделки от всех завершённых заказов	≤5 дней медиана исполнения стандартный заказ
≥99% полные отчёты обязательные ракурсы и чек-лист	0 несогласованных доплат технически запрещены	100% аудит критичных действий статусы, деньги, доступ, споры

Входит в MVP

- Публичный каталог услуг, FAQ, политика качества и форма заявки.
- Вход по одноразовому коду; русский и английский клиентский интерфейс.
- Цифровой паспорт захоронения: кладбище, участок, ориентиры, координата, фото, история.
- Заявка, диагностика, построчная смета, оплата, уведомления и статус заказа.
- Кабинет исполнителя с принятием назначения, мобильным чек-листом, фото и офлайн-очередью загрузки.
- Админ-панель диспетчера, QA, финансов и поддержки.
- Отчёт «до / выполнено / после» в web и PDF.
- Обращения/споры, возвраты, журнал действий и базовая аналитика.
- Провайдерные адаптеры для платежей, карт, SMS/e-mail и объектного хранилища.

Не входит в MVP

- Открытый marketplace, публичные ставки, прямой выбор исполнителя и автоматические выплаты.
- Нативные приложения iOS/Android; используется responsive web/PWA.
- Полноценная CRM, бухгалтерия, склад или ERP.
- Автоматическое распознавание памятника/повреждений как источник окончательного решения.
- Динамическая маршрутизация уровня курьерских сервисов; достаточно кластеров, календаря и ручного назначения.
- Публичные мемориальные страницы, социальные функции и размещение фото в поиске.
- Капитальные работы без отдельного специализированного процесса.

Ключевые допущения

ID	Допущение	Последствие для реализации
A-01	Оплата поступает оператору сервиса	Обычный интернет-эквайринг; safe-deal и массовые выплаты — позже
A-02	Исполнитель получает назначение, а не публичный заказ	Нет торгов; есть принять/отклонить и причина
A-03	Локализация первичной базы — РФ	PostgreSQL, object storage и бэкапы размещаются в российском ЦОД
A-04	Сложный заказ требует осмотра	Смета может создаваться в два этапа; нельзя оплатить неподтверждённый объём
A-05	Сеть работает при нестабильной связи	Чек-лист и фото должны переживать разрыв соединения
A-06	Фото — важное, но не абсолютное доказательство	Комбинировать метаданные, сессию, геозону, QA и журнал
A-07	Claude Code используется как основной coding-agent	Репозиторий содержит CLAUDE.md, ADR, тесты, hooks и малые вертикальные задачи

02 Роли, термины и продуктовая модель

Роли

Роль	Назначение	Ключевые права
Гость	Неавторизованный посетитель	Каталог, цены «от», FAQ, заявка, вход
Клиент	Заказывает уход и принимает результат	Захоронения, заявки, сметы, платежи, отчёты, обращения, согласия

Роль	Назначение	Ключевые права
Исполнитель	Выполняет назначенные работы	Профиль, доступность, принять/отклонить, чек-лист, фото, комментарий
Диспетчер	Проверяет заявку и назначает	Смета, календарь, назначение, изменение операционных сроков
QA-специалист	Проверяет качество	Просмотр отчёта, возврат на доработку, принятие, эскалация
Поддержка	Коммуникации и обращения	Диалоги, обращения, компенсации в пределах лимита
Финансы	Платежи, возвраты, выплаты и сверка	Транзакции, экспорт, ручная сверка, возвраты по роли
Администратор	Управление справочниками и доступом	Услуги, кладбища, пользователи, документы, настройки
Суперадминистратор	Аварийный и системный доступ	Назначение ролей, критичные настройки; отдельный аудит

Термины

Термин	Определение
Захоронение / Burial Site	Цифровая карточка конкретного места памяти; не официальный реестр и не подтверждение права на место
Заказ / Order	Согласованный набор работ в отношении одного захоронения и одного окна выполнения
Осмотр / Inspection	Отдельный визит для поиска, фиксации состояния и подготовки сметы
Смета / Estimate	Версионизируемый набор строк работ, материалов, скидок и итоговой суммы
Назначение / Assignment	Предложение конкретному исполнителю выполнить конкретный заказ
Визит / Visit	Фактическая сессия на месте: старт, геозона, чек-лист, медиа и завершение
Отчёт / Report	Принятая QA-версия результатов, доступная клиенту
Допработа / Extra	Новая строка сметы, обнаруженная после начала и требующая согласия клиента
Обращение / Dispute	Структурированная претензия или вопрос по заказу с доказательствами и сроком ответа
Legal Acceptance	Факт принятия конкретной версии оферты, политики или договора

Матрица доступа — принцип

Доступ строится по ролям и принадлежности объекта. Клиент видит только свои захоронения и заказы; исполнитель — только назначенные ему заказы и минимально необходимую информацию; QA и диспетчер — операционные данные; финансы — деньги без лишних фото; суперадминистратор не используется для повседневной работы.

Объект	Клиент	Исполнитель	Операции	Финансы
Данные клиента	свои	минимум для связи через маскированный канал	по роли	ФИО/контакт для возврата при необходимости
Координаты/фото	свои	только назначенный заказ	диспетчер/QA	нет по умолчанию
Смета и заказ	свои	состав работ без клиентской цены закупки	полный доступ по роли	денежные поля
Платёж	свой статус и чек/ссылка	нет	статус без реквизитов	полный операционный доступ
Аудит	свои значимые события	свои события	по полномочиям	финансовые события

03 Функциональные требования

Приоритеты: MUST — обязательны для запуска; SHOULD — реализовать, если не угрожает сроку и качеству; LATER — явно зафиксировано как продолжение. Каждый ID должен иметь минимум один автоматический или приёмочный тест.

Публичная часть и вход

ID	P	Требование	Критерий
FR-PUB-001	MUST	Главная страница объясняет услугу, процесс, гарантии, географию и ограничения	Без регистрации доступны RU/EN, СТА ведёт в заявку
FR-PUB-002	MUST	Каталог показывает пакеты, состав, цену «от», лимиты и допуслуги	Нельзя скрывать обязательные ограничения за tooltip
FR-PUB-003	MUST	Страница доверия описывает проверку исполнителей, фотоотчёт, QA, возвраты и конфиденциальность	Нет неподтверждённых обещаний «100% защита»
FR-PUB-004	MUST	FAQ покрывает поиск могилы, сроки, оплату, погоду, права на фото и сложные работы	Контент управляется из админки или CMS-слоя
FR-PUB-005	MUST	Форма предварительной заявки работает без аккаунта	После отправки создаётся lead и предлагается OTP-вход
FR-PUB-006	SHOULD	Посадочные страницы по кладбищам и услугам	Шаблон, индексируемый контент, корректные canonical/meta
FR-AUTH-001	MUST	Вход по одноразовому коду на телефон или e-mail	Код одноразовый, ограничен по сроку и попыткам
FR-AUTH-002	MUST	Создание пользователя происходит после подтверждения контакта и принятия документов	Сохраняется версия текста, время, IP/UA по политике
FR-AUTH-003	MUST	Сессии можно завершить на всех устройствах	Клиент видит активные сессии или доступна глобальная инвалидация
FR-AUTH-004	MUST	Административные роли используют MFA	Без второго фактора вход запрещён
FR-AUTH-005	MUST	Rate limiting и антибот-защита для OTP и публичных форм	Лимиты конфигурируются, события видны в логах

ID	P	Требование	Критерий
FR-AUTH-006	SHOULD	Восстановление доступа через поддержку при потере контакта	Процедура не раскрывает данные третьему лицу

Клиент: профиль, захоронения и заявки

ID	P	Требование	Критерий
FR-CUS-001	MUST	Клиент редактирует имя, язык, часовой пояс и каналы уведомлений	Изменения аудируются; контакт меняется через подтверждение
FR-CUS-002	MUST	Клиент создаёт карточку захоронения	Обязательны город/кладбище и минимум один набор идентифицирующих данных
FR-CUS-003	MUST	Карточка хранит ФИО усопшего, даты, участок/квартал, ориентиры, координату, фото и особые указания	Каждое поле имеет видимость и валидацию; даты могут быть неполными
FR-CUS-004	MUST	Несколько членов семьи могут быть добавлены как участники карточки	В MVP приглашённый может смотреть; право заказа — по явному разрешению
FR-CUS-005	MUST	Клиент создаёт заявку из карточки или с нуля	Пошаговая форма сохраняет черновик
FR-CUS-006	MUST	Система определяет достаточность локации	Недостаточные данные переводят заявку в LOCATION_REVIEW / осмотр
FR-CUS-007	MUST	Клиент выбирает пакет, желаемую дату/окно и добавляет комментарий	Интерфейс не обещает слот до подтверждения операций
FR-CUS-008	MUST	Клиент загружает исходные фото/схему	Private storage, допустимые типы/размер, антивирусная проверка
FR-CUS-009	MUST	Клиент видит версионизируемую смету построчно	Работы, количество, цена, материалы, скидка и итог
FR-CUS-010	MUST	Клиент принимает или отклоняет смету	Принятие конкретной версии фиксируется; после изменения нужно повторное согласие
FR-CUS-011	MUST	Клиент оплачивает заказ доступным способом	Методы приходят от провайдера динамически; статус обновляется webhook/polling
FR-CUS-012	MUST	Клиент видит таймлайн заказа	Каждый публичный статус имеет понятный текст и следующий шаг
FR-CUS-013	MUST	Клиент согласует доработку из заказа	Без согласия сумма и чек-лист не меняются; отказ не блокирует основной объём
FR-CUS-014	MUST	Клиент получает отчёт и может принять результат	Отчёт содержит смету, чек-лист, фото, рекомендации и дату
FR-CUS-015	MUST	Клиент открывает обращение с категорией и файлами	Доступно в гарантийное окно; создаётся SLA и номер
FR-CUS-016	MUST	Клиент повторяет заказ по сохранённому захоронению	Предзаполняются данные, но цена/дата подтверждаются заново

ID	P	Требование	Критерий
FR-CUS-017	SHOULD	Клиент настраивает памятные даты и сезонные напоминания	Часовой пояс учитывается; есть отписка по каналу
FR-CUS-018	SHOULD	Клиент покупает подписку на 2/4/6 визитов	Отображаются остаток визитов, окно и правила переноса
FR-CUS-019	MUST	Клиент запрашивает выгрузку и удаление профиля	Запрос проходит workflow; обязательные записи сохраняются по срокам
FR-CUS-020	SHOULD	Клиент скачивает PDF-отчёт и документы по заказу	PDF генерируется сервером, имеет номер/дату и не содержит внутренних заметок

Исполнитель

ID	P	Требование	Критерий
FR-EXE-001	MUST	Исполнитель проходит анкету и идентификацию	Статусы DRAFT → REVIEW → TEST → ACTIVE / REJECTED / SUSPENDED
FR-EXE-002	MUST	Профиль содержит географию, категории, транспорт, доступность и налоговый статус	Изменение критичных полей требует повторной проверки
FR-EXE-003	MUST	Исполнитель видит только предложенные/принятые назначения	Клиентские контакты маскируются; координата открывается по правилу
FR-EXE-004	MUST	Назначение можно принять или отклонить до дедлайна	Отказ требует причины, не создаёт скрытого наказания; событие аудируется
FR-EXE-005	MUST	Перед принятием видны категория, зона, окно, длительность, состав и вознаграждение	Нет скрытых обязательных работ
FR-EXE-006	MUST	Исполнитель запускает визит на месте	Фиксируются время, приблизительная геозона, устройство и заказ
FR-EXE-007	MUST	До работ обязательна верификация захоронения	Подтвердить признаки; при сомнении выбрать STOP_WRONG_LOCATION
FR-EXE-008	MUST	Фото «до» снимаются через приложение по обязательным ракурсам	По умолчанию нельзя закрыть этап без минимума кадров
FR-EXE-009	MUST	Чек-лист работает по пунктам: выполнено / невозможно / не требуется	Для отклонения обязательны причина и при необходимости фото
FR-EXE-010	MUST	Исполнитель предлагает доработку с фото, описанием и количеством	Предложение не даёт права выполнить её до согласования
FR-EXE-011	MUST	Фото «после» повторяют заданные ракурсы	Интерфейс показывает эталон «до» рядом с камерой/превью
FR-EXE-012	MUST	Можно завершить визит при временно отсутствующей сети	События и медиа становятся в локальную очередь; есть явный статус синхронизации
FR-EXE-013	MUST	Исполнитель видит замечания QA и выполняет доработку	Версии отчёта не перезаписываются; причина возврата обязательна
FR-EXE-014	MUST	Исполнитель видит начисление по принятому заказу	Сумма, статус и основание; выплаты в MVP могут проводиться вручную

ID	P	Требование	Критерий
FR-EXE-015	SHOULD	Исполнитель управляет календарём недоступности	Диспетчер не назначает в закрытые интервалы без явного override
FR-EXE-016	SHOULD	Исполнитель видит собственные метрики качества	Принятие, переделки, отмены, полнота отчётов; без непрозрачного рейтинга
FR-EXE-017	MUST	В приложении доступны техника безопасности и запрещённые действия	Критичные инструкции показываются по категории до начала визита
FR-EXE-018	MUST	Экстренная остановка заказа	Причины: опасность, неверное место, запрет администрации, повреждение; уведомить диспетчера

Операционная и административная часть

ID	P	Требование	Критерий
FR-ADM-001	MUST	Единая очередь заявок с фильтрами и SLA	Фильтры по статусу, кладбищу, дате, риску, оплате, исполнителю
FR-ADM-002	MUST	Диспетчер проверяет локацию и полноту данных	Решение, комментарий и следующий статус сохраняются
FR-ADM-003	MUST	Диспетчер создаёт и версионировать смету	Старые версии доступны; клиенту отправляется только опубликованная
FR-ADM-004	MUST	Назначение исполнителя учитывает категорию, зону, доступность и лимит	Система предупреждает о конфликте, но MVP допускает override с причиной
FR-ADM-005	MUST	Календарь показывает заказы и загрузку исполнителей	День/неделя; drag-and-drop не обязателен
FR-ADM-006	MUST	QA-очередь показывает непроверенные отчёты и риск-флаги	Есть сравнение «до/после», чек-лист и история замечаний
FR-ADM-007	MUST	QA принимает, возвращает или эскалирует отчёт	Причина обязательна; действие запускает уведомления и SLA
FR-ADM-008	MUST	Поддержка ведёт обращения в карточке заказа	Категория, приоритет, переписка, вложения, ответственный, дедлайн
FR-ADM-009	MUST	Финансы видят платежи, возвраты и ручные выплаты	Сверка по provider ID и idempotency key
FR-ADM-010	MUST	Возврат создаётся только пользователем с правом и в пределах лимита	Для превышения лимита — двухэтапное одобрение
FR-ADM-011	MUST	Справочник услуг и чек-листов версионирован	Изменение не меняет уже оплаченный заказ
FR-ADM-012	MUST	Справочник кладбищ содержит зоны, часы, правила и контакты	История изменений; публичность поля настраивается
FR-ADM-013	MUST	Управление исполнителями: допуски, категории, документы, приостановка	Блокировка не удаляет историю заказов
FR-ADM-014	MUST	Управление ролями по least privilege	Назначение привилегированной роли требует MFA и аудита
FR-ADM-015	MUST	Управление версиями юридических документов	Публикация задаёт effective_at; принятия привязаны к версии
FR-ADM-016	SHOULD	Экспорт заказов и финансов в CSV/XLSX	Экспорт маскирует поля по роли и фиксируется в аудите

ID	P	Требование	Критерий
FR-ADM-017	SHOULD	Операционный дашборд	Воронка, SLA, качество, экономика, исполнители и кластеры
FR-ADM-018	MUST	Имперсонация клиента запрещена; режим поддержки — read-only by default	Любое действие от имени клиента требует отдельного подтверждения/лога
FR-ADM-019	MUST	Ручное изменение статуса ограничено переходами	Нельзя перепрыгнуть финансовый/QA-контроль; override только с причиной
FR-ADM-020	SHOULD	Шаблоны сообщений управляются без деплоя	RU/EN, переменные валидируются, preview до публикации

Системные функции

ID	P	Требование	Критерий
FR-SYS-001	MUST	Уведомления генерируются из доменных событий	Шаблон + канал + язык; повтор не создаёт дубликат
FR-SYS-002	MUST	Фоновые задачи имеют повтор, backoff и dead-letter	Ошибка видна в мониторинге; можно безопасно повторить
FR-SYS-003	MUST	Медиа загружаются напрямую в object storage по signed URL	Сервер выдаёт ограниченный URL и подтверждает завершение
FR-SYS-004	MUST	Все webhook обрабатываются идиempотентно	Повтор одного provider event не меняет баланс/статус дважды
FR-SYS-005	MUST	PDF-отчёт генерируется из зафиксированной версии данных	Повторная генерация воспроизводима; внутренние поля исключены
FR-SYS-006	MUST	Аудит критичных действий неизменяем на уровне приложения	Actor, action, object, before/after, timestamp, request/correlation ID
FR-SYS-007	MUST	Справочники и feature flags конфигурируются по окружению	Секреты не хранятся в репозитории
FR-SYS-008	SHOULD	События аналитики имеют единую схему	Версия события, user/order ID с псевдонимизацией, source/utm
FR-SYS-009	MUST	Все деньги хранятся целым числом копеек и валютой	Нет float в домене и БД
FR-SYS-010	MUST	Все времена хранятся в UTC	Отображение учитывает timezone пользователя/заказа

04 Процессы, статусы и бизнес-правила

Статусная модель заказа

Order status меняется только доменной командой, проверяющей допустимый переход и полномочия. UI не записывает статус напрямую. Платёж, визит, QA и спор имеют собственные состояния; агрегированный статус заказа вычисляется или меняется оркестратором.

Статус	Смысл	Разрешённый следующий шаг
DRAFT	Черновик клиента или оператора	SUBMITTED / CANCELLED
SUBMITTED	Заявка отправлена	LOCATION_REVIEW / ESTIMATE_READY / CANCELLED

Статус	Смысл	Разрешённый следующий шаг
LOCATION_REVIEW	Нужно уточнить или найти место	ESTIMATE_READY / CANCELLED
ESTIMATE_READY	Смета опубликована клиенту	AWAITING_PAYMENT / CANCELLED / новая версия ESTIMATE_READY
AWAITING_PAYMENT	Смета принята, ожидается платёж	PAID / CANCELLED
PAID	Платёж подтверждён	ASSIGNING / CANCELLED / REFUNDED
ASSIGNING	Операция ищет исполнителя	ASSIGNED / CANCELLED
ASSIGNED	Исполнитель принял назначение	IN_PROGRESS / ASSIGNING / CANCELLED
IN_PROGRESS	Визит начат	EXTRA_APPROVAL / QA_REVIEW / CANCELLED по аварийному сценарию
EXTRA_APPROVAL	Ожидается решение по доработке	IN_PROGRESS / QA_REVIEW
QA_REVIEW	Отчёт проверяет QA	IN_PROGRESS (доработка) / CUSTOMER_REVIEW / DISPUTED
CUSTOMER_REVIEW	Результат опубликован клиенту	COMPLETED / DISPUTED
COMPLETED	Работа принята или автопринята по правилу	DISPUTED в гарантийное окно
DISPUTED	Открыто обращение по качеству/деньгам	COMPLETED / IN_PROGRESS / REFUNDED / CANCELLED
CANCELLED	Заказ отменён	конечный; деньги обрабатываются отдельным workflow
REFUNDED	Подтверждён полный возврат и заказ закрыт	конечный

Публичные статусы

Внутренние статусы	Текст клиенту	СТА
DRAFT	Черновик	Продолжить
SUBMITTED / LOCATION_REVIEW	Проверяем данные	Добавить сведения
ESTIMATE_READY	Смета готова	Посмотреть и подтвердить
AWAITING_PAYMENT	Ожидается оплата	Оплатить
PAID / ASSIGNING	Организуем выполнение	Связаться с поддержкой
ASSIGNED	Исполнитель назначен	Посмотреть срок
IN_PROGRESS / EXTRA_APPROVAL	Работа выполняется	Согласовать доработку, если есть
QA_REVIEW	Проверяем качество	Ожидать
CUSTOMER_REVIEW	Отчёт готов	Принять или сообщить о проблеме
COMPLETED	Завершено	Скачать отчёт / повторить
DISPUTED	Обращение рассматривается	Открыть переписку
CANCELLED / REFUNDED	Отменено / возвращено	Посмотреть детали

Основные процессы

Процесс	Последовательность	Контрольная точка
Стандартный заказ	Заявка → смета → согласие → платёж → назначение → визит → QA → клиент → завершение	Нельзя начать без успешного платежа и принятого назначения
Заказ с осмотром	Заявка → платный/служебный осмотр → паспорт → новая смета → платёж → основной визит	Осмотр и основной заказ связаны, но имеют отдельные расчёты/визиты
Допработа	Исполнитель фиксирует проблему → диспетчер оценивает → клиент принимает/отклоняет → доплата → выполнение	Исполнитель не выполняет до согласия; основной объём может продолжаться
QA-доработка	Отчёт → QA возвращает пункты → исполнитель повторно загружает → новая версия отчёта	История версий и причин сохраняется
Спор	Клиент открывает → triage → доказательства → решение → переделка/компенсация/отказ → закрытие	SLA, ответственный, журнал и уведомления
Отмена	Запрос → проверка стадии и затрат → расчёт возврата → provider refund → закрытие	Нельзя обещать возврат до подтверждения провайдером

Бизнес-правила

ID	Правило
BR-001	Один order относится ровно к одному burial_site и одному service window; семейный маршрут — набор связанных заказов.
BR-002	Оплачивается только опубликованная и принятая версия estimate; изменение строк инвалидирует согласие.
BR-003	Сумма order_total = сумма строк - скидки; хранится в копейках, отрицательный итог запрещён.
BR-004	Ни одна доплата не выполняется и не списывается без отдельного принятия клиентом и подтверждённой доплаты/лимита.
BR-005	Исполнитель может принять или отклонить assignment до deadline; молчание означает истечение, а не принятие.
BR-006	Один активный assignment на заказ; повторное назначение закрывает предыдущее с причиной.
BR-007	Визит можно начать только для принятого assignment и допустимого статуса заказа.
BR-008	Минимальный набор фото и чек-листа определяется версией service_package, зафиксированной в заказе.
BR-009	Критичное отклонение (неверная локация, опасность, запрет администрации) немедленно блокирует продолжение.
BR-010	Отчёт клиенту публикуется только после QA, кроме специально разрешённого low-risk сценария, выключенного по умолчанию.
BR-011	Автопринятие возможно по конфигулируемому сроку после публикации отчёта, если нет обращения; клиент заранее уведомляется.

ID	Правило
BR-012	Гарантийное окно считается от публикации/принятия отчёта и задаётся версией услуги.
BR-013	Refund никогда не меняет финансовый статус до подтверждения provider webhook или ручной сверки.
BR-014	Удаление пользователя — soft delete/anonymization workflow; платежи, договорные принятия и аудит сохраняются по срокам.
BR-015	Публичная ссылка на media запрещена; доступ только через короткоживущий signed URL после авторизации.
BR-016	Версия юридического документа не редактируется после публикации; создаётся новая версия.
BR-017	Изменение справочника услуги не меняет исторический snapshot заказа.
BR-018	Любой административный override требует reason_code, комментариев и запись AuditLog.

Состояния платежа и возврата

Объект	Статусы	Примечание
Payment	CREATED, PENDING, SUCCEEDED, CANCELLED, FAILED, EXPIRED	SUCCEEDED устанавливается только по проверенному webhook/API
Refund	REQUESTED, APPROVAL_REQUIRED, PROCESSING, SUCCEEDED, FAILED, CANCELLED	Поддерживает полный/частичный возврат
Payout	DRAFT, APPROVED, PAID, FAILED, HELD	В MVP может быть ручной реестр; домен готов к provider integration
Invoice/Receipt	NOT_REQUIRED, PENDING, ISSUED, ERROR	Фактическая схема зависит от кассы и налоговой модели

05 Информационная модель и хранение данных

Принципы модели

- UUID/ULID идентификаторы; внешние provider ID хранятся отдельно и уникальны в рамках провайдера.
- Все изменяемые коммерческие сущности имеют version или snapshot: смета, пакет, чек-лист, юридический документ.
- Транзакционные данные нормализованы; аналитика получает события/витрины, но не становится источником истины.
- Soft delete применяется к пользовательским объектам; финансовые и аудиторские записи не удаляются обычным CRUD.
- Медиа хранится вне БД; в БД — metadata, hash, owner, purpose, lifecycle status и storage key.

Сущности домена

Сущность	Ключевые поля	Связи / инварианты
User	id, status, locale, timezone, verified contacts, created_at	1:1/0..1 customer_profile; 1:1/0..1 executor_profile; роли через memberships
CustomerProfile	display_name, notification preferences, deletion_status	Владеет burial_site access и orders

Сущность	Ключевые поля	Связи / инварианты
ExecutorProfile	legal/tax status, zones, categories, availability, onboarding_status	Допуски версионизируются; статус ACTIVE обязателен для assignment
RoleMembership	user_id, role, scope, valid_from/to	Least privilege; history не перезаписывается
Cemetery	name, region, address, geo boundary, hours, rules, contacts	Может иметь clusters/zones и внутренние инструкции
BurialSite	cemetery_id, person data, plot/section, coordinates, landmarks, notes, risk flags	Доступ через BurialSiteMember; не официальный реестр
BurialSiteMember	burial_site_id, user_id, permission, invited_by	VIEW / ORDER / MANAGE; приглашение подтверждается
ServicePackage	code, version, locale content, price_from, limits, warranty_days	Snapshot попадает в order
ChecklistTemplate	package_version, items, required media rules	Версия неизменна после использования
Order	customer, burial_site, package_snapshot, status, window, totals, source	Один активный order flow; status no state machine
Estimate	order_id, version, status, valid_until, totals	Только одна опубликованная версия; acceptance на конкретную version
EstimateLine	type, title, qty, unit, unit_price, tax, metadata	type: WORK/MATERIAL/DISCOUNT/DELIVERY/EXTRA
Assignment	order_id, executor_id, offered_at, deadline, decision, reward	Один accepted active assignment на order
Visit	assignment_id, start/end, geo, device/session, stop_reason	Может иметь попытки/доработку; linked media/checklist
ChecklistItemResult	visit_id, template_item_id, result, note	Отклонение требует reason; immutable versions
MediaAsset	owner_type/id, phase, storage_key, mime, size, hash, capture metadata, moderation	Private; lifecycle UPLOADING/READY/QUARANTINED/DELETED
Payment	order_id, provider, amount, currency, status, idempotency_key, provider_id	Уникальность provider event; append-only transitions
Refund	payment_id, amount, reason, status, approvals	Сумма не превышает доступный refundable amount
Payout	executor_id, assignment/order, amount, status, external_ref	Не создаётся до принятия QA, если иное не установлено
Report	order_id, version, published_at, summary, recommendations, pdf_asset_id	Публикуется только approved QA-version
Dispute	order_id, category, status, SLA, resolution, compensation	Сообщения и вложения; appeal-ready history
Subscription	customer, burial_site, plan, visits_total/used, period, status	Создаёт orders по календарю после подтверждения окна
LegalDocument	type, version, locale, content_hash, effective_at, status	Published version immutable
LegalAcceptance	user, document_version, accepted_at, context, evidence	Нельзя удалять вместе с профилем обычной операцией
AuditLog	actor, action, object, before/after hash/json, request_id, timestamp	Write-only application path; restricted read

Классификация и сроки хранения

Класс	Примеры	Требование	Базовая политика
P0 — секреты	API keys, signing secrets, DB credentials	Только secret manager; никогда в БД бизнес-приложения/логах	Ротация и немедленное аннулирование при инциденте

Класс	Примеры	Требование	Базовая политика
P1 — высокочувствительные	Документы исполнителя, точные координаты, private media	Шифрование, строгие роли, аудит доступа	Минимально необходимый срок + legal hold
P2 — персональные	Контакты, имя клиента, переписка, устройства	Основание/цель, локализация, права субъекта	По политике и договорам; затем удаление/анонимизация
P3 — коммерческие	Сметы, выплаты, внутренние оценки	Ролевой доступ, целостность, резервное копирование	По бухгалтерским/договорным срокам
P4 — публичные	Каталог, FAQ, публичные правила	Контроль версии и публикации	Хранить историю опубликованных версий

Медиа-пайплайн

- 1. Клиент/исполнитель запрашивает upload session; backend проверяет право, purpose и лимиты.
- 2. Backend выдаёт signed PUT/POST URL с коротким TTL и ограничением content-type/size.
- 3. Клиент загружает объект напрямую; затем вызывает complete или система получает storage event.
- 4. Worker проверяет MIME/magic bytes, размер, hash, антивирус, удаляет лишние EXIF-поля по политике и создаёт preview.
- 5. До статуса READY файл не отображается; подозрительный файл получает QUARANTINED и уведомление оператора.
- 6. Выдача происходит по signed GET URL после каждой проверки ACL; CDN не должен делать объект публичным.

06 API и интеграции

API-конвенции

Параметр	Требование
Base path	/api/v1; versioning меняется только для breaking changes
Transport	HTTPS only; JSON UTF-8; multipart не используется для больших файлов — только signed upload
Auth	HttpOnly Secure SameSite cookie для web; CSRF-защита для state-changing запросов
IDs	UUID/ULID как opaque string; клиент не делает выводов из формата
Idempotency	Idempotency-Key обязателен для создания платежа, возврата и иных денежных команд
Concurrency	Optimistic locking через version/If-Match для смет, статусов и админ-редактирования
Pagination	Cursor-based для журналов/заказов; limit ≤100
Errors	Единый envelope: code, message, field_errors, request_id; безопасное сообщение пользователю
Dates	ISO 8601 UTC; локализация только на клиенте/представлении
Money	{amount_minor: integer, currency: 'RUB'}
Audit	Каждая команда получает actor, request_id/correlation_id и source

Параметр	Требование
Documentation	OpenAPI 3.1 генерируется/проверяется в CI и доступна только авторизованной команде либо отдельным public scope

Клиентские endpoint-группы

Метод и путь	Назначение	Особенности
POST /auth/otp/request	Запрос кода	Rate limit; не раскрывает существование аккаунта
POST /auth/otp/verify	Проверка кода / сессия	Возвращает профиль и required legal acceptances
POST /auth/logout	Завершить сессию	Инвалидация refresh/session
GET/PATCH /me	Профиль и настройки	Контакт меняется отдельной процедурой
GET/POST /burial-sites	Список / создание карточки	Доступ по membership
GET/PATCH /burial-sites/{id}	Карточка захоронения	Optimistic lock; приватные поля
POST /burial-sites/{id}/members	Пригласить участника	Токен с TTL; permission VIEW/ORDER/MANAGE
GET/POST /orders	Список / создание заказа	Черновик или SUBMITTED
GET /orders/{id}	Карточка и таймлайн	Публичная проекция без внутренних заметок
POST /orders/{id}/submit	Отправить заявку	Проверка минимальных данных
GET /orders/{id}/estimates	Версии сметы	Только опубликованные клиенту
POST /orders/{id}/estimate-acceptance	Принять/отклонить версию	Documented consent; version обязательна
POST /orders/{id}/payments	Создать платёж	Idempotency-Key; provider adapter
POST /orders/{id}/extras/{extraId}/decision	Согласовать допработу	ACCEPT/REJECT; при ACCEPT создаётся payment intent
GET /orders/{id}/report	Web-отчёт	Доступ после публикации
GET /orders/{id}/report.pdf	Скачать PDF	Signed/streamed response; audit download
POST /orders/{id}/accept	Принять результат	Только CUSTOMER_REVIEW
POST /orders/{id}/disputes	Открыть обращение	Категория, текст, media IDs
GET/POST /disputes/{id}/messages	Переписка	Append-only messages; attachments private
POST /media/upload-sessions	Создать upload session	Purpose + owner object + mime/size
POST /media/{id}/complete	Подтвердить загрузку	Запускает scan/processing

Endpoint-группы исполнителя

Метод и путь	Назначение	Контроль
GET/PATCH /executor/profile	Профиль и доступность	Критичные изменения → REVIEW
GET /executor/assignments	Предложения и активные назначения	Только текущий исполнитель
POST /assignments/{id}/decision	Принять/отклонить	Deadline, reason, optimistic lock
POST /assignments/{id}/visits	Начать визит	Проверка статуса и active assignment

Метод и путь	Назначение	Контроль
GET /visits/{id}/checklist	Версия чек-листа	Snapshot на момент заказа
PUT /visits/{id}/checklist/{itemId}	Сохранить результат пункта	Идемпотентный upsert по client_event_id
POST /visits/{id}/location-verification	Подтвердить место / остановиться	Evidence + result
POST /visits/{id}/extras	Предложить допроботу	Фото/описание/qty; не выполняет автоматически
POST /visits/{id}/complete	Завершить и отправить в QA	Проверка обязательных пунктов/media
GET /visits/{id}/qa-feedback	Замечания QA	Версии и unresolved items
POST /visits/{id}/resubmit	Повторная отправка	Новая report version
GET /executor/earnings	Начисления	Без клиентской цены и лишних PII

Endpoint-группы backoffice

Метод и путь	Назначение
GET /admin/orders	Очередь с фильтрами, сортировкой, SLA и risk flags
POST /admin/orders/{id}/location-review	Подтвердить/запросить данные/создать inspection
POST /admin/orders/{id}/estimates	Создать черновик версии сметы
POST /admin/estimates/{id}/publish	Опубликовать версию клиенту
POST /admin/orders/{id}/assignments	Предложить заказ исполнителю
POST /admin/assignments/{id}/revoke	Отозвать назначение с причиной
GET /admin/qa/reports	QA-очередь
POST /admin/reports/{id}/decision	APPROVE / REWORK / ESCALATE
GET/POST /admin/disputes	Очередь и управление обращениями
POST /admin/refunds	Запрос возврата; approvals по лимиту
GET /admin/payments/reconciliation	Сверка provider events и внутренних транзакций
GET/POST/PATCH /admin/service-packages	Справочник и версии услуг
GET/POST/PATCH /admin/cemeteries	Справочник кладбищ/зон/правил
GET/POST/PATCH /admin/executors	Допуск, категории, приостановка
GET/POST /admin/legal-documents	Черновики и версии документов
POST /admin/legal-documents/{id}/publish	Неизменяемая публикация effective version
GET /admin/audit	Поиск по критичным действиям с отдельным разрешением

Webhooks

Путь	Требования
POST /webhooks/payments/{provider}	Проверка подписи/источника, raw body, idempotency, быстрый 2xx, обработка в очереди
POST /webhooks/storage/{provider}	Подтверждение объекта/scan event; недоверенный input, allowlist event types

Путь	Требования
POST /webhooks/messages/{provider}	Delivery status для SMS/e-mail; не принимать команды пользователя через неподтверждённый канал

Интеграции и provider interfaces

Интеграция	MVP	Интерфейс / требования
Платежи	YooKassa или эквивалентный РФ-провайдер; карты/СБП по доступности	PaymentProvider: create, get, cancel, refund, verifyWebhook; методы показываются динамически
Safe deal / выплаты	Не обязательно; ручной реестр начислений	PayoutProvider закладывается, но не блокирует запуск; safe-deal — после юридической модели
Карты	Yandex Maps/Geocoder через адаптер	MapProvider: geocode, reverse, static preview; не считать кладбищенские проходы точной навигацией
Object storage	S3-compatible private bucket в РФ	StorageProvider: signed upload/download, head, delete, lifecycle; versioning по необходимости
SMS	Российский SMS-провайдер через адаптер	MessageProvider; шаблоны, rate limit, delivery callback
E-mail	Транзакционный провайдер	SPF/DKIM/DMARC, locale templates, suppression list
PDF	Серверный HTML → PDF	Renderer отделён от домена; фиксированные шрифты и тесты snapshot
НПД	LATER или ручная проверка	TaxStatusProvider: verify status/receipt; хранить результат и дату проверки
Антивирус	ClamAV/managed scanner	ScanResult, quarantine, timeout/retry; no public delivery before CLEAN
Observability	OpenTelemetry + logs/metrics/error tracker	PII redaction, trace/correlation ID, environment separation

Доменные события

Событие	Потребители
OrderSubmitted	SLA, уведомление операции, аналитика
EstimatePublished / Accepted	Уведомление клиента, payment eligibility, аудит
PaymentSucceeded / Failed / Refunded	Order orchestrator, финансы, уведомления, аналитика
AssignmentOffered / Accepted / Declined / Expired	Диспетчеризация, уведомления, метрики supply
VisitStarted / Stopped / Submitted	SLA, QA queue, risk detection
ExtraProposed / Accepted / Rejected	Смета, платёж, исполнитель, уведомления
ReportApproved / Published / Accepted	PDF, клиент, payout eligibility, retention
DisputeOpened / Resolved	Поддержка, SLA, выплаты hold, аналитика
LegalDocumentPublished / Accepted	Access gate, audit, compliance exports

07 Интерфейсы и UX-сценарии

Дизайн-принципы

- Спокойный, деликатный визуальный язык; отсутствие агрессивных таймеров, красных «срочно» и манипуляции чувством вины.
- На каждом шаге видны текущий статус, следующий шаг, срок и ответственный контур.
- Цена показывается вместе с составом и ограничениями; «от» не маскирует обязательный осмотр.
- Основные действия доступны одной рукой на мобильном устройстве; формы сохраняют черновик.
- Фото и координаты по умолчанию приватны; интерфейс явно предупреждает перед приглашением родственника или публикацией кейса.
- Ошибки объясняют, что произошло и что делать; внутренние коды/stack trace не показываются.

Клиентские экраны

Экран	Ключевые блоки	Основное действие
Главная	Обещание, как работает, пакеты, доверие, кейсы с согласием, FAQ	Создать заявку / заказать осмотр
Каталог услуги	Состав, лимиты, цена от, сроки, FAQ, примеры результата	Выбрать услугу
Wizard заявки	Локация → сведения → фото → услуга → дата → контакты → review	Отправить
Вход / ОTR	Контакт, код, согласия	Подтвердить
Мои места памяти	Карточки, следующий визит, состояние, участники	Открыть / добавить
Карточка захоронения	Карта/схема, сведения, приватные фото, история, напоминания	Заказать уход
Карточка заказа	Статус, таймлайн, смета, оплата, сообщения, отчёт	Контекстный СТА
Смета	Версия, строки, материалы, скидки, итог, срок действия	Принять / задать вопрос
Оплата	Доступные методы от провайдера, сумма, статус	Оплатить / повторить безопасно
Согласование доплаты	Фото проблемы, описание, строка цены, влияние на срок	Принять / отказаться
Отчёт	До/после по ракурсам, чек-лист, рекомендации, документы	Принять / открыть обращение
Обращение	Категория, описание, вложения, SLA, переписка	Отправить / ответить
Настройки	Профиль, язык, уведомления, сессии, данные/удаление	Сохранить

Исполнительские экраны — mobile first

Экран	Ключевые блоки	Офлайн-поведение
Лента назначений	Новые/сегодня/доработка, зона, окно, вознаграждение	Последняя синхронизированная версия read-only
Карточка предложения	Состав, ограничения, инструменты, маршрут, deadline	Решение требует сеть либо локальную очередь с предупреждением

Экран	Ключевые блоки	Офлайн-поведение
Подготовка	Правила кладбища, чек-лист вещей, контакт диспетчера	Кэшируется после принятия
Старт визита	Проверка места, геозона, existing damage, фото «до»	Можно собрать локально; сервер валидирует при супс
Чек-лист	Пункты, причины отклонения, прогресс, таймер необязательный	Полностью редактируемый локально; конфликт решается по client_event_id
Допработа	Фото, тип, объём, комментарий; цена задаётся диспетчером	Черновик сохраняется; отправка при сети
Фото «после»	Эталонный ракурс «до», камера, качество, повтор	Файлы в encrypted app storage до подтверждённой загрузки
Отправка в QA	Сводка, незавершённые пункты, очередь файлов	Нельзя считать отправленным, пока сервер не подтвердил
Доработка	Замечания QA по пунктам/фото	Кэшируется; новая версия не затирает старую
Начисления	Принятые работы, сумма, hold/paid	Read-only кэш

Backoffice-экраны

Экран	Функция
Операционный дашборд	SLA, новые заявки, сегодня, просрочки, QA, споры, payment issues
Очередь заявок	Фильтры, bulk-safe actions, приоритет, cemetery cluster, risk flags
Карточка заказа 360°	Клиент, место, сметы, платежи, назначения, визиты, медиа, QA, обращения, аудит
Редактор сметы	Строки, лимиты, шаблоны, версия, preview клиентского вида
Календарь / назначение	Исполнители, зоны, доступность, конфликт, предложение и deadline
QA workbench	Синхронное сравнение ракурсов, чек-лист, zoom, замечания, decision
Исполнители	Onboarding, допуски, документы, тесты, качество, приостановка
Финансы	Платежи, возвраты, начисления, сверка, экспорт
Обращения	SLA, категории, переписка, решение, компенсация, appeal history
Справочники	Пакеты, чек-листы, кладбища, зоны, правила, шаблоны сообщений
Юридические документы	Версии, locale, preview, effective date, статистика принятия
Аудит	Поиск actor/action/object/request; экспорт только отдельной ролью

UX-правила критических сценариев

Сценарий	Правило
Неверная могила	Исполнитель нажимает «не уверен / не то место»; приложение запрещает перейти к уборке и открывает связь с диспетчером

Доступность и локализация

- WCAG 2.2 AA как цель: клавиатура, focus, контраст, label/error associations, reduced motion, semantic headings.
- Кнопки и поля на мобильном — не менее 44×44 CSS px; критичные действия не зависят только от цвета.
- RU/EN строки вынесены в каталоги; pluralization и формат денег/дат — через locale, без склейки фраз.
- Имена и адреса допускают кириллицу/латиницу; даты жизни могут быть неизвестны частично.
- Alt-текст служебных фотографий генерируется из типа ракурса, но приватные сведения не попадают в публичный DOM/метаданные.

08 Архитектура и рекомендуемый стек

Архитектурное решение

Модульный монолит в TypeScript с двумя процессами: web/API и worker. Он быстрее и безопаснее для MVP, чем микросервисы, но границы доменов и provider interfaces позволяют позже отделить платежи, медиа или диспетчеризацию.

Логическая схема



Cross-cutting: Auth • Legal versions • RBAC • Audit • Observability • Feature flags

Рекомендуемый стек

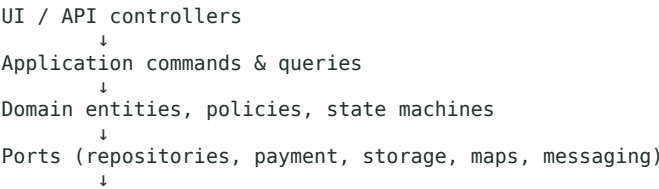
Слой	Выбор	Причина / ограничение
Monorepo	pnpm workspaces + Turborepo (или простой pnpm без Turborepo)	Единые типы/правила; не усложнять pipeline без пользы
Web	Next.js, TypeScript strict, App Router	SSR/SEO для публичной части, PWA и один язык стека
UI	Tailwind CSS + shadcn/ui + собственные design tokens	Быстрый старт, доступные primitives, контроль внешнего вида
Forms	React Hook Form + Zod	Общие схемы валидации клиента и сервера
API	REST route handlers/controllers + OpenAPI 3.1	Явный контракт для PWA, backoffice и будущих приложений
Domain	Чистые TypeScript-модули без зависимости от UI/ORM	State machine и бизнес-правила тестируются отдельно
DB	PostgreSQL; Prisma ORM и миграции	Транзакции, зрелость, типизация; одна ORM во всём проекте
Jobs	pg-boss	Очередь поверх PostgreSQL без Redis на MVP; retry/dead-letter
Storage	S3-compatible private object storage в РФ	Signed URL, lifecycle, масштабирование медиа

Слой	Выбор	Причина / ограничение
Auth	Проверенная session/auth library + OTP provider adapter; admin MFA	Не писать собственную криптографию; хранить hash токенов
i18n	next-intl или эквивалент	RU/EN, server/client messages, locale routing
Logs	Pino structured JSON + PII redaction	Поиск и корреляция без свободного console.log
Tracing/metrics	OpenTelemetry + совместимый backend	Связь web, worker, provider calls и jobs
Tests	Vitest, Testing Library, Playwright, Testcontainers/isolated PostgreSQL	Пирамида тестов и реальные интеграции БД
Runtime	Node.js LTS; Docker images с pinned digest	Воспроизводимость и обновления по регламенту
Hosting	Российский дата-центр; Docker Compose/managed Postgres на старте	Локализация, простой rollback и резервное копирование

Модули приложения

Модуль	Ответственность	Не должен
identity	Пользователи, контакты, сессии, роли, MFA	Знать детали заказов
legal	Документы, версии, принятия, access gates	Редактировать опубликованную версию
burial-sites	Карточки, участники, локация, приватность	Считать себя официальным реестром
catalog	Пакеты, версии, чек-листы, ограничения	Менять исторический snapshot
orders	Order aggregate, статусы, сроки, source	Обрабатывать provider webhook напрямую
estimates	Версии и строки сметы, acceptance, extras	Использовать float
dispatch	Assignments, eligibility, availability, workload	Автоматически штрафовать за отказ
visits	Сессия на месте, verification, checklist, offline events	Публиковать отчёт клиенту
media	Upload, scan, metadata, signed access, lifecycle	Делать bucket/public URL источником доступа
payments	Payment/refund/payout state, provider adapter, reconciliation	Доверять redirect пользователя как подтверждению
reports	QA versions, публикация, PDF	Показывать внутренние комментарии
disputes	Обращения, SLA, доказательства, решения	Удалять историю решений
subscriptions	Планы, визиты, календарь, renewals	Автосоздавать платёж без разрешённой схемы
notifications	События → шаблон → канал → delivery	Содержать бизнес-истину о статусе
audit	Критичные события и поиск	Позволять обычный update/delete
analytics	События и агрегаты	Влиять на транзакционные решения

Правила зависимостей



Infrastructure adapters (Prisma, provider SDKs, S3, pg-boss)

Запрещено: domain → Next.js/Prisma/provider SDK.
Разрешено: infrastructure реализует интерфейсы domain/application.

Транзакции и согласованность

- Одна бизнес-команда выполняется в одной DB-транзакции; внешние вызовы — через outbox/job после commit.
- Provider webhook сначала сохраняется как уникальное inbound event, затем обрабатывается worker; повтор безопасен.
- Изменение order/estimate использует optimistic version; конфликт возвращает 409 и актуальное состояние.
- Публикация отчёта атомарно фиксирует approved version и создаёт события уведомления/PDF.
- Удаление объекта storage происходит асинхронно после фиксации tombstone и окончания retention/hold.

ADR, обязательные до кода

ADR	Решение
ADR-001	Управляемый сервис против marketplace; границы ответственности
ADR-002	Модульный монолит и границы модулей
ADR-003	Auth/session/OTP/MFA и модель ролей
ADR-004	Хранение медиа, EXIF, signed URLs и retention
ADR-005	Платёжный flow, чеки, возвраты и idempotency
ADR-006	Offline event queue исполнителя и конфликт-стратегия
ADR-007	Локализация данных и выбор инфраструктуры
ADR-008	Order state machine и разделение order/payment/visit states

09 Безопасность, персональные данные и соответствие

	Базовый принцип Фото, точные координаты, контакты и сведения о семье не должны становиться публичными по ошибке. Безопасность реализуется как проверяемые требования и тесты, а не как финальная «проверка перед релизом».
--	--

Модель угроз

Актив / риск	Пример угрозы	Основная защита
Аккаунт клиента	Перехват OTP, credential stuffing, session theft	Короткий OTP, rate limit, secure cookies, session revocation, device signals
Координаты и фото	IDOR, публичный bucket, утечка signed URL	Object-level authorization, private storage, TTL, аудит, случайные keys
Админка	Компрометация сотрудника или избыточные права	MFA, RBAC, IP/device policy по возможности, least privilege, audit

Актив / риск	Пример угрозы	Основная защита
Платежи	Повтор webhook, подмена суммы, доверие redirect	Signature verify, idempotency, server-side amount, reconciliation
Загрузка файлов	Malware, polyglot, oversized file, metadata leak	Signed constraints, magic bytes, scan, resize, EXIF policy, quarantine
API	IDOR, mass assignment, injection, abuse	Policy checks, allowlist DTO, Zod, parameterized ORM, rate limits
Worker/jobs	Повтор выполнения и двойной денежный эффект	Idempotent handlers, unique keys, transaction/outbox, dead-letter
Логи/аналитика	PII попадает в free-form logging	Structured allowlist, redaction, lint/hook, restricted access
Исполнительское устройство	Потеря телефона и локальные фото	Encrypted storage where available, short session, remote revoke, cleanup after sync
Внутренний злоумышленник	Просмотр чужих карточек или экспорт	Need-to-know roles, access logs, export audit, alerts on bulk access

Требования безопасности

ID	Требование
SEC-001	TLS 1.2+; HSTS в production; HTTP перенаправляется на HTTPS.
SEC-002	Session cookies: HttpOnly, Secure, SameSite; rotation после входа/повышения роли; server-side revoke.
SEC-003	ОТР хранится только в виде hash, TTL ≤10 минут, лимит попыток и cooldown; ответ не раскрывает наличие аккаунта.
SEC-004	MFA обязательно для admin/QA/finance/superadmin; восстановление MFA — отдельная проверяемая процедура.
SEC-005	Object-level authorization вызывается для каждого read/write; тесты IDOR обязательны для orders, burial sites, media, disputes.
SEC-006	DTO используют allowlist; mass assignment и передача role/status/amount из недоверенного клиента запрещены.
SEC-007	CSRF-защита для cookie-auth state changes; CSP, X-Content-Type-Options, Referrer-Policy и безопасные frame rules.
SEC-008	Платёжные суммы и order ID берутся из БД; redirect/callback браузера не подтверждает оплату.
SEC-009	Webhook signature/secret и replay protection; raw body; уникальный provider_event_id; обработка идемпотентна.
SEC-010	Object storage private; ACL public запрещён policy/IaC; signed GET TTL конфигурируемый и короткий.
SEC-011	Upload: allowlist форматов, лимит размера/количества, magic bytes, AV scan, image re-encode/preview, quarantine.
SEC-012	Секреты только в secret manager/environment injection; .env.example без значений; secret scanning в CI и hooks.
SEC-013	Логи не содержат ОТР, токены, документы, полные контакты, точные координаты и media URLs; redaction тестируется.
SEC-014	AuditLog для ролей, договоров, статусов, смет, платежей, возвратов, exports, media access и overrides.

ID	Требование
SEC-015	Зависимости и контейнеры сканируются; критические уязвимости блокируют release либо требуют оформленного risk acceptance.
SEC-016	Резервные копии шифруются, доступ ограничен; restore test проводится регулярно и документируется.
SEC-017	Production data не копируется в dev/test; тестовые данные синтетические или необратимо обезличенные.
SEC-018	Есть incident playbook: обнаружение, ограничение, ротация секретов, уведомления, форензика, postmortem.

Персональные данные и локализация

Контроль	Реализация в продукте
Реестр целей	Для каждого поля/события указать purpose, legal basis, recipients, retention, owner
Privacy notice	RU/EN, версия, дата действия, понятный перечень данных и прав
Consent	Использовать только там, где это корректное основание; не объединять необязательный маркетинг с сервисным согласием
Локализация	Первичная запись данных граждан РФ в БД на территории РФ; storage/backups также проектировать в РФ
Поручение обработки	Договоры и реестр provider/subprocessor; передавать минимум данных
Трансграничная передача	Не включать по умолчанию; отдельная правовая оценка до зарубежного analytics/support/provider
Права субъекта	Экспорт, исправление, удаление/ограничение через workflow и верификацию
Retention	Конфигурируемые сроки + legal hold; автоматические jobs и отчёт об удалении
Уведомление РКН	Юрист определяет необходимость и содержание до production; доказательство решения хранится в compliance docs
Privacy by default	Фото/координаты private; приглашённый родственник получает минимальное право; маркетинг выключен до opt-in

Готовность к закону о платформенной экономике

На дату ТЗ закон № 289-ФЗ должен вступить в силу 1 октября 2026 года. Финальная квалификация продукта зависит от реальной договорной и операционной схемы. Даже при управляемом сервисе рекомендуется сохранить следующие возможности, чтобы переход к посреднической платформе не потребовал переписывать ядро.

Требование готовности	Реализация
Электронные договоры с партнёрами	LegalDocument/Acceptance, version, effective_at, доступ в кабинете
Проверка сведений	Executor onboarding, verification records, expiration, re-check
Прозрачность правил	Версии условий, service rules, payout/quality policies

Требование готовности	Реализация
Рейтинг и ограничения	Сначала прозрачные метрики; любое снижение/блокировка имеет reason и appeal trail
Расчёты	Ledger-like payment/payout records, reconciliation, statements
Жалобы и апелляции	Dispute entity, SLA, structured evidence, decision and appeal history
Свобода исполнения	Accept/decline per assignment, availability, per-order reward, отсутствие скрытого фиксированного графика

Политика доступа к фотографиям

- Клиентские исходные фото: клиент, участники карточки по разрешению, диспетчер/QA и назначенный исполнитель в нужный период.
- Фото визита до публикации: исполнитель, диспетчер и QA; клиент получает approved report, а не внутренние неудачные кадры.
- После закрытия заказа доступ исполнителя прекращается через конфигурируемый срок, кроме открытой доработки/спора.
- Скачивание оригинала может быть ограничено; клиенту достаточно оптимизированного качества и PDF, если договором не обещано иное.
- Любое использование в маркетинге — отдельный объект согласия с выбором конкретных изображений и возможностью отзыва на будущее.

10 Нефункциональные требования и эксплуатация

NFR

ID	Категория	Требование / измерение
NFR-001	Производительность	Публичные страницы: p75 LCP ≤2,5 с на типичном 4G; CLS ≤0,1; INP ≤200 мс в целевой выборке.
NFR-002	API	p95 ≤500 мс для обычных read/write без внешнего провайдера; тяжёлые операции уходят в job и возвращают 202/status.
NFR-003	Доступность	Цель MVP 99,5% в месяц без учёта заранее объявленных работ; status/maintenance page и graceful degradation.
NFR-004	Надёжность	Ни один повтор запроса/webhook/job не создаёт двойной платёж, возврат, назначение или публикацию отчёта.
NFR-005	Масштаб	Архитектура поддерживает ≥5 000 заказов/мес. и ≥500 000 media assets без смены доменной модели.
NFR-006	Резервирование	Production DB: point-in-time recovery по возможностям платформы; целевые RPO ≤15 мин, RTO ≤4 ч после проверки.
NFR-007	Совместимость	Последние две стабильные версии Chrome, Safari, Edge, Firefox; mobile Safari/Chrome обязательны.
NFR-008	PWA/offline	Executor flow сохраняет обязательные данные локально и явно показывает супс state; потеря сети не теряет уже сделанные фото/пункты.

ID	Категория	Требование / измерение
NFR-009	Доступность	Цель WCAG 2.2 AA; axe/Playwright checks в CI + ручная клавиатурная проверка критичных flows.
NFR-010	Локализация	RU/EN без hard-coded пользовательских строк; timezone/locale форматирование; fallback RU.
NFR-011	Наблюдаемость	100% запросов получают request_id; trace связывает API, job и provider call; error alert содержит безопасный контекст.
NFR-012	Поддерживаемость	TypeScript strict, lint/format, cyclomatic/complexity guard по разумным порогам, публичные модули документированы.
NFR-013	Тестируемость	Domain/application не зависят от browser/ORM; provider adapters имеют contract tests и sandbox/fake implementations.
NFR-014	Миграции	DB migration backwards-compatible для rolling/fast rollback где возможно; destructive migration — отдельный runbook.
NFR-015	Конфиденциальность	PII не попадает в клиентскую аналитику без минимизации; private media никогда не индексируется и не кэшируется публично.
NFR-016	Документация	Setup, architecture, API, domain, security, runbooks и acceptance обновляются в том же PR, что и поведение.

Окружения

Окружение	Данные	Интеграции	Доступ
local	Синтетические fixtures	Fake providers / local S3 emulator / sandbox по необходимости	Разработчик
dev	Синтетические общие данные	Sandbox providers; автоматический deploy main/branch preview по политике	Команда
staging	Псевдореальные сценарии без production PII	Sandbox или изолированные test accounts; production-like config	Команда + приёмка
production	Реальные данные	Production providers, private network/controls	Ограниченные роли, MFA, break-glass

CI/CD pipeline

- 7. Install из lockfile; проверка версий Node/pnpm.
- 8. Format/lint, forbidden patterns, secret scan и dependency audit.
- 9. Typecheck всех workspace.
- 10. Unit + domain tests; coverage по критичным модулям.
- 11. Integration tests с временной PostgreSQL и fake/sandbox adapters.
- 12. Build web/worker; OpenAPI diff; migration dry-run.
- 13. Playwright critical paths на preview/staging.
- 14. Container scan/SBOM; подпись image при доступности.
- 15. Deploy staging → smoke → ручное approval production.

16. Post-deploy smoke, migration check, alerts; rollback по runbook.

Мониторинг и алерты

Сигнал	Порог / событие	Реакция
HTTP errors	5xx rate выше baseline; auth/payment endpoints отдельно	Alert on-call, trace/request IDs, rollback при релизной корреляции
Latency	p95/p99 деградация в течение окна	Проверить DB/provider/jobs; включить degradation
Queue	Oldest job age, retries, dead-letter >0 для critical queue	Оператор/разработчик; безопасный replay
Payments	Webhook signature failures, mismatch, pending слишком долго	Finance + engineering; reconciliation
Media	Scan backlog, upload failures, public ACL detection	Блокировать публикацию; security alert
Auth	OTP spikes, brute force, admin MFA failures	Rate limit/temporary block, security review
Data	Backup failure, replication/PITR issue, disk growth	Высокий приоритет; не ждать следующего дня
Business SLA	Просроченные назначения, QA, disputes	Операционный alert, не технический incident

Backup и disaster recovery

- Автоматические DB backups и PITR; backup storage отделён по учётным данным и политике доступа.
- Object storage использует versioning/lifecycle по оценке риска; удаление защищено retention/soft-delete workflow.
- Не реже ежеквартально на MVP проводится restore drill в изолированное окружение с измерением RPO/RTO.
- Runbook содержит владельца, порядок остановки записи, восстановление, проверку целостности платежей и коммуникацию.
- После восстановления выполняется сверка order/payment/provider events и выборочная проверка media/report links.

Runbooks, обязательные к запуску

Файл	Содержание
runbooks/payment-webhook-lag.md	Проверка провайдера, pending payments, replay, reconciliation
runbooks/refund-failed.md	Безопасный повтор/ручная сверка, коммуникация клиенту
runbooks/media-upload-failure.md	Очередь, локальные файлы исполнителя, повторная загрузка
runbooks/wrong-burial-site.md	Остановка, доказательства, уведомление, новый поиск
runbooks/data-incident.md	Ограничение, ротация, оценка, уведомления и postmortem
runbooks/db-restore.md	PITR/backup restore, validation, cutover/rollback
runbooks/release-rollback.md	Критерии, команды, DB compatibility, verification
runbooks/provider-outage.md	Degraded mode, отключение метода, очередь, статус пользователю

11 Тестирование и критерии приёмки

Стратегия тестирования

Уровень	Что тестируем	Инструмент / подход
Unit	State machines, money, estimates, permissions policies, status transitions, retention calculations	Vitest; без БД и framework
Integration	Repositories, transactions, outbox/jobs, migrations, authorization against real PostgreSQL	Ephemeral DB/Testcontainers; deterministic fixtures
Contract	Payment/storage/maps/message adapters и webhook parsing	Provider sandbox/fake; recorded fixtures без секретов
Component	Формы, error states, tables, media queue UI, i18n	Testing Library; accessibility assertions
E2E	Критичные customer/executor/backoffice flows	Playwright в staging-like environment
Security	IDOR, CSRF, upload abuse, rate limits, session/MFA, secret/log leaks	Автотесты + ручной review + dependency/container scan
Performance	Публичные страницы, API hotspots, media upload, queues	Lighthouse/Web Vitals, k6/Artillery или аналог
Recovery	DB restore, replay webhook, dead-letter replay, provider outage	Runbook drill; фиксированный протокол
UAT	Реальные сценарии диспетчера, QA и исполнителя	Чек-листы приёмки на тестовых захоронениях/демо-данных

Обязательные тестовые наборы

- Переходы каждого order status: разрешённый, запрещённый, повторный и конфликт версий.
- Смета: rounding, discounts, materials, extra, invalidated acceptance, currency/money serialization.
- Платёж: duplicate create, duplicate webhook, out-of-order events, mismatch amount/order, partial/full refund.
- Доступ: клиент А не читает burial site/order/media клиента В; исполнитель не читает неназначенный заказ; finance не видит private media.
- Медиа: неправильный MIME, oversized, interrupted upload, scan timeout, quarantined, signed URL expiry.
- Offline: 20+ checklist/media events без сети, restart приложения, повторная синхронизация, duplicate client_event_id.
- QA: возврат, повторная версия, сравнение, публикация только approved report.
- Спор: гарантийное окно, SLA, hold выплаты, решение переделка/компенсация/отказ, аудит.
- Legal: новый документ блокирует требуемое действие, старая acceptance не принимается за новую.
- Localization/accessibility: RU/EN, клавиатура, screen reader labels, error summary, mobile viewport.

Критерии приёмки MVP

ID	Критерий
AC-001	Гость создаёт заявку RU/EN, подтверждает контакт и продолжает без потери введенных данных.
AC-002	Клиент создаёт карточку захоронения с приватными фото; другой клиент не получает объект ни по UI, ни прямым API ID.
AC-003	Диспетчер публикует смету; клиент принимает конкретную версию; изменение сметы требует нового согласия.

ID	Критерий
AC-004	Платёж создаётся идиempотентно; только проверенный webhook переводит его в SUCCEEDED и заказ в PAID.
AC-005	Диспетчер предлагает назначение; исполнитель видит объём/вознаграждение и может принять или отклонить.
AC-006	Исполнитель не может начать визит до принятия назначения и не может перейти к работе без верификации места.
AC-007	Чек-лист и фото сохраняются при разрыве сети и синхронизируются без дубликатов после восстановления.
AC-008	Допработа не выполняется и не меняет сумму без отдельного клиентского согласия и оплаты/разрешённого лимита.
AC-009	Неполный отчёт нельзя отправить в QA; неутверждённый QA отчёт нельзя показать клиенту.
AC-010	Клиент принимает отчёт или открывает обращение; обращение создаёт SLA, переписку и audit trail.
AC-011	Возврат проходит role/limit approval и не становится успешным до provider confirmation.
AC-012	Пользователь может скачать PDF approved report; PDF не содержит внутренних комментариев, точных служебных данных и broken media.
AC-013	Административный вход требует MFA; попытки изменения роли/статуса/денег фиксируются в AuditLog.
AC-014	Private media не доступно публичной ссылкой; signed URL истекает и проверяется object-level authorization.
AC-015	CI проходит lint, typecheck, unit/integration/E2E critical paths, OpenAPI check и security scans.
AC-016	Production deploy имеет smoke test, мониторинг, backup и проверенный rollback/restore runbook.

Definition of Ready для задачи

Проверка	Обязательно
Ссылка на FR/BR/AC	Да; либо задача обновляет T3/ADR до кода
User value и роль	Одно предложение без технического жаргона
Happy path + ошибки	Минимум основной, отказ, retry/idempotency, permission denied
Данные/API	Схема, миграция, privacy class, retention, event impact
UI	Состояния loading/empty/error/success, mobile, RU/EN, accessibility
Тесты	Перечень unit/integration/E2E и security checks
Rollout	Feature flag, migration/deploy order, rollback
Открытые решения	Нет блокирующих; принятые оформлены ADR или явно delegated

Трассируемость

Каждый PR указывает: requirement IDs → изменённые модули → тесты → migration/API diff → security/privacy impact → screenshots для UI. CI может проверять наличие секций в шаблоне PR, но содержательность остаётся предметом review.

12 Организация разработки в Claude Code

Как трактуется vibe coding

	Контролируемый режим Claude Code может читать репозиторий, менять файлы и запускать команды; CLAUDE.md даёт постоянный контекст, subagents изолируют специализированные задачи, а hooks детерминированно запускают проверки. Но архитектурные решения, платежи, безопасность и приёмка остаются под ответственностью человека. [C1–C5]
--	---

Неправильный подход	Требуемый подход
«Сделай весь сервис» одним промптом	Один вертикальный срез с FR/AC, планом, тестами и review
Доверять устной истории чата	Решения живут в CLAUDE.md, docs и ADR; чат можно очистить
Разрешить любые команды	Permission rules + hooks; destructive/production команды блокируются
Просить Claude выбирать всё на ходу	Критичные stack/architecture decisions приняты заранее или оформлены ADR
Проверять только глазами демо	Unit/integration/E2E, security checks, migration/recovery drill
Параллельно менять много доменов	Малые PR, один owner aggregate, совместимые миграции
Считать сгенерированный код готовым	Человек читает diff, проверяет threat/privacy impact и принимает

Обязательные документы репозитория

Файл	Назначение
CLAUDE.md	Краткие постоянные правила проекта, команды, архитектурные запреты и workflow
docs/PRODUCT.md	Ценность, роли, scope MVP/out, продуктовые принципы
docs/DOMAIN.md	Сущности, инварианты, state machines, glossary
docs/ARCHITECTURE.md	Слои, модули, зависимости, provider ports, diagrams
docs/API.md + openapi.yaml	API-конвенции, auth, errors и контракт
docs/SECURITY.md	Threat model, secure coding, data classes, incident links
docs/PRIVACY.md	Data inventory, purposes, retention, localization, processors
docs/ACCEPTANCE.md	AC-001...016 и UAT сценарии

Файл	Назначение
docs/adr/ADR-*.md	Необратимые/дорогие решения и последствия
runbooks/*.md	Эксплуатационные и аварийные процедуры
CHANGELOG.md	Пользовательские и операционные изменения

Содержание корневого CLAUDE.md

Файл должен быть коротким и конкретным; процедуры и большие справочники выносятся в docs/rules/skills. Официальная документация рекомендует хранить там то, что иначе приходится повторять в каждой сессии, а детерминированные запреты обеспечивать hooks. [C2, C3]

```
# Память рядом – правила для Claude Code

## Цель
Строим управляемый сервис ухода за захоронениями. MVP не является открытым marketplace.

## Перед изменениями
1. Прочитай связанный FR/BR/AC и релевантный ADR.
2. Сформулируй план, затрагиваемые модули, риски данных/денег и тесты.
3. Не начинай код, если требование противоречиво: обнови спес/ADR или зафиксируй blocker.

## Архитектура
- TypeScript strict; модульный монолит.
- Domain не импортирует Next.js, Prisma или provider SDK.
- Деньги – integer minor units; время – UTC.
- Status меняется только через domain state machine.
- External calls после commit через outbox/job.
- Private media – только signed URLs после object authorization.
- Provider SDK доступен только из infrastructure adapters.

## Безопасность
- Не логируй PII, OTP, токены, координаты и signed URLs.
- Не доверяй browser redirect для платежа.
- Любая денежная команда и webhook идиempотентны.
- Не изменяй roles/status/amount из произвольного client payload.
- Никогда не обращай к production и не читай реальные .env/secrets.

## Команды
- pnpm lint
- pnpm typecheck
- pnpm test
- pnpm test:integration
- pnpm test:e2e
- pnpm build

## Готовность
Изменение завершено только когда обновлены код, тесты, OpenAPI/миграция, docs/ADR и acceptance evidence.
```

Проектные rules

Для правил, относящихся только к определённым путям, создать `claude/rules/` с path-scoped инструкциями: `domain.md`, `payments.md`, `media.md`, `migrations.md`, `ui.md`, `tests.md`. Критичные правила, которые должны переживать смену контекста, дублировать кратко в корневом CLAUDE.md.

Subagents

Файл	Режим	Задача
.claude/agents/domain-architect.md	read-only	Проверить границы модулей, инварианты и state transition; вернуть риски и минимальный план
.claude/agents/security-reviewer.md	read-only	Проверить authz, payments, uploads, logs, secrets, threat cases и предложить тесты
.claude/agents/test-designer.md	read/write tests при разрешении	Составить negative/idempotency/concurrency cases и тестовые fixtures

Файл	Режим	Задача
.claude/agents/migration-reviewer.md	read-only	Проверить backward compatibility, locks, backfill, rollback и PII impact
.claude/agents/api-contract-reviewer.md	read-only	Сверить OpenAPI, DTO, errors, versioning и authorization
.claude/agents/ux-accessibility.md	read-only	Проверить mobile states, RU/EN, keyboard, screen reader и деликатность текста

Subagents применяются для задач, которые создают много вспомогательного контекста или требуют отдельной специализации; итог возвращается в основную сессию в виде краткого отчёта. [C4]

Hooks — детерминированные ограничения

Hook	Действие	Примечание
PreToolUse: shell	Блокировать `rm -rf`, force push, production URLs/DB, чтение secret files, опасные миграции без флага	Matcher и JSON schema сверить с установленной версией Claude Code
PreToolUse: edit/write	Запрещать изменение generated/vendor/lockfile без задачи; предупреждать о payment/security paths	Не заменяет code review
PostToolUse: edit/write	Запускать formatter/lint для изменённых файлов и secret/PII pattern scan	Быстро; полный test suite не запускать на каждый файл
PostToolUse: migration	Проверять migration lint/dry-run и наличие rollback note	Отдельный скрипт проекта
Stop	Проверять чистоту formatter/typecheck, наличие тестов/docs в diff и выводить незавершённые проверки	Не заявлять успех, если команды не выполнены

Hooks нужны там, где правило должно выполняться всегда, а не зависеть от решения модели. Официальная документация прямо различает CLAUDE.md как контекст и hooks как механизм детерминированного контроля. [C2, C5]

Протокол одной сессии

- 17. Начать с чистого контекста для новой несвязанной задачи; загрузить только релевантные docs и файлы.
- 18. Дать Claude одну задачу: goal, FR/BR/AC, ограничения, touched modules, non-goals.
- 19. Попросить сначала исследовать существующий код и выдать план/риски без изменений.
- 20. После одобрения плана реализовать минимальный вертикальный срез, а не абстракции «на будущее».
- 21. Сначала/параллельно написать failing tests для инвариантов, permissions и edge cases.
- 22. Запустить точечные тесты, затем полный required pipeline; не скрывать skipped/failed.
- 23. Попросить отдельный security/test subagent проверить diff.
- 24. Просмотреть diff человеком, выполнить UAT, обновить docs/ADR/CHANGELOG и только затем merge.
- 25. Между несвязанными задачами очищать контекст; постоянные решения переносить из чата в репозиторий.

Шаблон задачи для Claude Code

Задача: <одно проверяемое изменение>
Ценность: <для какой роли и зачем>
Требования: FR-..., BR-..., AC-...
Не входит: <явные границы>
Сначала:
1) прочитай <файлы>;
2) найди затрагиваемые модули и существующие паттерны;
3) предложи план, риски денег/PII/конкурентности и тесты;
4) не редактируй код до плана.
При реализации:
- минимальный diff;

- backward-compatible migration;
 - object-level auth;
 - idempotency для повторов;
 - RU/EN + loading/empty/error;
 - unit + integration + E2E по критичному пути.
- В конце:
- перечисли изменённые файлы;
 - команды и фактические результаты;
 - незакрытые риски;
 - соответствие каждому AC.

Правила human review

Область	Минимум два человека / повышенное внимание
Платежи и возвраты	Да: domain invariant, provider flow, webhook, reconciliation, money tests
Auth/RBAC/PII/media	Да: security review и negative access tests
DB migrations с backfill/delete	Да: план блокировок, backup, dry-run, rollback
Order state machine	Product/operations + engineer; влияние на старые заказы
Обычный UI/content	Один reviewer + automated checks; деликатность текста проверяется отдельно

13 План реализации и Definition of Done

Вертикальные итерации

Итерация считается завершённой только при демонстрации сквозного пользовательского результата, а не набора незаконченных слоёв. Порядок допускает корректировку после concierge-пилота, но денежные и security-инварианты не откладываются.

Итерация	Вертикальный результат	Ключевые проверки
V0 — Foundation	Monorepo, окружения, CI, PostgreSQL, миграции, logging/tracing, design tokens, docs/ADR	Build/test/deploy preview, secrets policy, DB restore smoke
V1 — Identity & Legal	OTP, session, customer/admin roles, MFA, версии документов и acceptance	Brute-force, session revoke, RBAC, audit, RU/EN
V2 — Burial Sites	Создание/редактирование карточки, private media, участники и permissions	IDOR, signed URLs, upload scan, invitation permissions
V3 — Order & Estimate	Заявка, location review, пакет, версия сметы, принятие	State transitions, optimistic lock, money, invalidated consent
V4 — Payment	Создание платежа, webhook, pending/success/fail, сверка	Idempotency, replay, amount mismatch, provider outage
V5 — Dispatch	Исполнители, допуски, availability, offer/accept/decline, calendar queue	Eligibility, deadline, one active assignment, audit
V6 — Visit & Offline	Location verification, before/checklist/after, local queue, sync	Offline restart, duplicate events, required media, stop reasons
V7 — QA & Report	QA workbench, rework versions, client report, PDF, acceptance	No publish before approval, media ACL, PDF snapshot
V8 — Extras & Disputes	Допработа, доплата, обращение, SLA, решение, refund workflow	No work without consent, hold, approvals, provider confirmation
V9 — Backoffice	Catalog/checklist versions, cemeteries, legal docs, finance/export, audit search	Historical snapshots, role scopes, export audit

Итерация	Вертикальный результат	Ключевые проверки
V10 — Subscriptions & Retention	Планы визитов, напоминания, повтор заказа, privacy requests	No unauthorized recurring charge, timezone, deletion workflow
V11 — Hardening & Pilot Release	Performance, accessibility, DR, security review, UAT, runbooks, monitoring	AC-001...016, restore drill, rollback, incident simulation

Минимальный состав команды

Роль	Ответственность в разработке
Product owner / основатель	Приоритет, scope, бизнес-правила, принятие результата, связь с операциями
Tech lead / senior full-stack	Архитектура, security-critical code, migrations, review сгенерированного кода
Full-stack engineer	Вертикальные срезы, UI/API/tests, provider adapters
UX/UI + content	Критичные flows, mobile исполнитель, доступность, RU/EN и деликатный tone
QA / operations representative	UAT, чек-листы, edge cases реального кладбища, отчётность
Юрист / privacy / бухгалтер — fractional	Договоры, 152-ФЗ, 289-ФЗ readiness, платежи/чеки/НПД
Claude Code	Coding agent: исследование репозитория, реализация, тесты и документация под контролем команды

Definition of Done

- Поведение соответствует FR/BR/AC; scope и non-goals не нарушены.
- Код проходит formatter, lint, typecheck, unit и требуемые integration/E2E tests.
- Permissions, idempotency, concurrency, retry и error states проверены для затронутого flow.
- Миграция reviewed, применима к пустой и текущей БД, имеет rollback/backout plan и не использует production data в тесте.
- OpenAPI, event schema, docs/ADR/CHANGELOG обновлены; нет расхождения между кодом и документами.
- RU/EN, mobile, loading/empty/error/success и keyboard accessibility проверены.
- Логи/метрики/алерты добавлены; PII и секреты не попадают в telemetry.
- Feature flag/rollout и rollback определены; smoke test создан или обновлён.
- Diff прочитан человеком; security-critical изменение прошло второе review.
- Есть evidence: test output, screenshots/recording UI и короткое описание проверки AC.

Release gates

Gate	Условие выпуска
GATE-1 Functional	Все MUST требования выбранного релиза и AC-001...016 имеют статус PASS или оформленный deferred decision
GATE-2 Security	Нет открытых critical/high без формального исключения; IDOR/payment/upload cases пройдены
GATE-3 Data	Локализация и processors подтверждены; privacy docs опубликованы; retention jobs готовы
GATE-4 Money	Provider production account, webhook, reconciliation, refund runbook и чек/касса проверены
GATE-5 Operations	Исполнители/диспетчер/QA прошли UAT; есть поддержка и эскалация

Gate	Условие выпуска
GATE-6 Reliability	Monitoring, alerting, backup, restore и rollback проверены
GATE-7 Legal	Юрист письменно подтвердил договорную модель, оферты, правила кладбищ и 289-ФЗ qualification/readiness

Pilot readiness checklist

Область	Готово, когда
Каталог	Для каждого пакета есть версия, чек-лист, лимиты, warranty и операционный owner
Кладбища	Для пилотных кластеров заполнены адреса, часы, правила, риски и контакты
Supply	Активные исполнители имеют категории/зоны, тестовый заказ и согласованные условия
Поддержка	Шаблоны сообщений, SLA, компенсационные лимиты и emergency contact доступны
Платежи	Тестовые и production сценарии: success, pending, fail, refund, duplicate webhook
Privacy	Уведомление/решение РКН, локальная инфраструктура, consent/notice и access matrix
Качество	QA видит обязательные ракурсы и умеет вернуть конкретный пункт на доработку
Аналитика	Источник, воронка, труд/дорога/материалы, переделка и contribution записываются
Коммуникация	RU/EN тексты проверены; нет вины, давления и неподтверждённых гарантий

14 Приложения: структура репозитория, промпт, решения

Рекомендуемая структура репозитория

```
pamyat-ryadom/
├── apps/
│   ├── web/
│   └── worker/
├── packages/
│   ├── domain/
│   ├── application/
│   ├── db/
│   ├── contracts/
│   ├── ui/
│   ├── config/
│   └── testkit/
├── docs/
│   ├── PRODUCT.md
│   ├── DOMAIN.md
│   ├── ARCHITECTURE.md
│   ├── API.md
│   ├── SECURITY.md
│   ├── PRIVACY.md
│   ├── ACCEPTANCE.md
│   └── adr/
├── runbooks/
├── .claude/
│   ├── agents/
│   ├── rules/
│   └── commands/
└── # Next.js: public, customer, executor, admin, REST API
    # pg-boss jobs, providers, PDF, notifications, scans
    # entities, value objects, policies, state machines
    # commands, queries, orchestration, ports
    # Prisma schema, migrations, repositories
    # Zod DTO, OpenAPI, event schemas
    # components and design tokens
    # typed environment config
    # factories, fake providers, fixtures
```

```
├─ settings.json
├─ CLAUDE.md
├─ docker-compose.yml
├─ pnpm-workspace.yaml
├─ package.json
└─ .env.example
```

Master prompt для первого запуска Claude Code

Ты работаешь в новом репозитории MVP «Память рядом».

Цель первой задачи: подготовить foundation V0, не реализуя бизнес-функции.

Источник истины:

- это T3;
- docs/PRODUCT.md, DOMAIN.md, ARCHITECTURE.md, SECURITY.md, ACCEPTANCE.md;
- ADR-001...008.

Сначала:

1. предложи окончательную структуру моногитеро и список ADR, которые нужно заполнить;
2. выбери минимальные зависимости; объясни каждую;
3. опиши команды local setup, CI и production-like staging;
4. составь threat/privacy checklist для foundation;
5. дождись явного решения по плану до редактирования.

После плана создай:

- pnpm workspace;
- apps/web и apps/worker;
- packages/domain/application/db/contracts/ui/config/testkit;
- TypeScript strict, lint, format, test, build;
- PostgreSQL + pg-boss + S3 emulator в docker-compose;
- typed env validation и .env.example без секретов;
- structured logging с redaction;
- OpenTelemetry bootstrap;
- health/readiness endpoints;
- CI pipeline;
- документацию и первый restore/runbook skeleton.

Ограничения:

- не подключай production providers;
- не создавай auth/payment/order tables до соответствующей итерации;
- не используй float для будущих денег;
- не импортируй Prisma/Next.js в domain;
- не оставляй TODO без issue/reference;
- не заявляй, что всё готово, пока команды реально не выполнены.

В конце верни:

- дерево файлов;
- принятые решения и альтернативы;
- результаты команд;
- риски и следующий минимальный vertical slice.

Минимальный .env.example

```
APP_ENV=local
APP_BASE_URL=http://localhost:3000
DATABASE_URL=postgresql://...
JOB_DATABASE_URL=postgresql://...
SESSION_SECRET=replace-me
OTP_PROVIDER=fake
EMAIL_PROVIDER=fake
SMS_PROVIDER=fake
PAYMENT_PROVIDER=fake
MAP_PROVIDER=fake
STORAGE_ENDPOINT=http://localhost:9000
STORAGE_REGION=local
STORAGE_BUCKET_PRIVATE=pamyat-private
STORAGE_ACCESS_KEY=replace-me
STORAGE_SECRET_KEY=replace-me
OTEL_EXPORTER_OTLP_ENDPOINT=
LOG_LEVEL=info
FEATURE_SUBSCRIPTIONS=false
FEATURE_SAFE_DEAL=false
```

Фактические названия переменных согласовать с typed config; production secrets не передаются через `.env` в репозитории и не выводятся командой диагностики.

Seed-сценарии для разработки и UAT

Сценарий	Данные	Что проверяет
S-01 Стандарт	Известное место, базовый пакет, успешная оплата и отчёт	Happy path AC-001...012
S-02 Нужен поиск	Нет участка/координаты, есть ФИО и ориентир	LOCATION_REVIEW, inspection, новая смета
S-03 Допраба отказ	После старта найден заросший цветник; клиент отказывается	Основной объём продолжается, сумма не меняется
S-04 Допраба согласована	Покраска ограды после фото	Версия extra, доплата, чек-лист и отчёт
S-05 Неверное место	Сходная фамилия/даты	Stop workflow, no cleaning, диспетчерская эскалация
S-06 Offline	Связь пропала после 5 фото и половины чек-листа	Local queue, restart, no data loss/duplicates
S-07 QA rework	Не повторён ракурс «после»	Return, new version, client sees approved only
S-08 Спор	Клиент сообщает о пропущенном пункте	SLA, evidence, rework/compensation, audit
S-09 Платёж webhook duplicate	Один event доставлен 3 раза	Один payment transition, один receipt/event
S-10 Privacy	Клиент В угадывает ID клиента А	404/403 без утечки существования; security audit

Открытые решения до V1

ID	Решение	Владелец / критерий
OD-01	Юридическая модель: собственная услуга оператора или посредническая платформа	Основатель + юрист; определяет договоры, выплаты и 289-ФЗ
OD-02	Фискализация и чек: агентская/неагентская схема, provider/cashbox	Бухгалтер + юрист + payment provider
OD-03	OTP: телефон, e-mail или оба на старте	Product + стоимость/доставляемость/аудитория abroad
OD-04	Точный payment provider и доступные методы для нерезидентов	Фактический merchant account и тесты, без маркетинговых обещаний
OD-05	Хостинг/DB/storage в РФ и резервный регион	Security/privacy + бюджет + SLA
OD-06	Сроки хранения original media и локальных offline copies	Privacy + договор + операционные споры
OD-07	Автопринятие отчёта и гарантийное окно по пакетам	Product/operations/legal
OD-08	Модель начисления исполнителю и момент выплаты	Economics/legal; QA/спор hold
OD-09	Какие работы требуют отдельных разрешений по каждому пилотному кладбищу	Operations + администрация/юрист
OD-10	Нужна ли первая версия подписки или достаточно повторного заказа/напоминаний	Результаты concierge-пилота
OD-11	Способ маскированной связи клиент-исполнитель	Product/privacy; по умолчанию через поддержку

ID	Решение	Владелец / критерий
OD-12	Порог/алгоритм risk flags фото и геозоны	QA/security; не делать автоматическое обвинение

Запреты для автоматического coding-agent

- Не подключаться к production, реальным клиентским данным и платёжному кабинету без отдельной человеческой процедуры.
- Не запускать destructive migration, force push, удаление bucket/DB или массовую рассылку.
- Не менять юридический текст, цены, warranty и компенсационные лимиты как «технический рефакторинг».
- Не добавлять SDK/библиотеку без проверки лицензии, активности, уязвимостей и причины в PR.
- Не отключать тест/линтер/типизацию ради зелёного pipeline; исправить причину или оформить решение.
- Не генерировать фиктивные evidence, результаты команд, screenshots или claims о безопасности.

15 Источники

Источники проверены 21 августа 2026 года. Для нормативных требований использовать действующий официальный/справочный текст и юридическую проверку; для Claude Code — документацию версии, установленной в проекте.

Законодательство и официальные сервисы

- [L1] [Федеральный закон от 31.07.2025 № 289-ФЗ](#) — платформенная экономика
- [L2] [Статья 5 закона № 289-ФЗ](#) — договоры, проверка и правила платформы
- [L3] [Статья 14 закона № 289-ФЗ](#) — досудебные жалобы
- [L4] [Статья 15 закона № 289-ФЗ](#) — исполнители-физические лица
- [L5] [Статья 23 закона № 289-ФЗ](#) — вступление в силу 1 октября 2026 года
- [L6] [Постановление Правительства РФ от 06.06.2026 № 760](#) — критерии отношений на цифровых платформах
- [L7] [152-ФЗ, статья 18](#) — локализация и обязанности оператора
- [L8] [Роскомнадзор — уведомление об обработке персональных данных](#) — официальная форма
- [L9] [ФНС России — налог на профессиональный доход](#) — официальный ресурс

Платежи

- [P1] [YooKassa — способы оплаты](#) — актуальные методы и сценарии
- [P2] [YooKassa — СБП](#) — интеграционный сценарий
- [P3] [YooKassa — безопасная сделка: основы](#) — возможный post-MVP контур
- [P4] [YooKassa — безопасная сделка: платежи](#) — сценарий платежей платформы

Claude Code

- [C1] [Claude Code Docs — Overview](#) — возможности coding-agent
- [C2] [Claude Code Docs — How Claude remembers your project](#) — CLAUDE.md и постоянный контекст
- [C3] [Claude Code Docs — Extend Claude Code](#) — rules, skills, subagents, hooks и расширения
- [C4] [Claude Code Docs — Create custom subagents](#) — изолированные специализированные агенты
- [C5] [Claude Code Docs — Automate actions with hooks](#) — детерминированные проверки и ограничения
- [C6] [Claude Code Docs — Best practices](#) — управление контекстом и рабочий процесс

Финальное правило
ТЗ готово для старта репозитория, но значения из блока «Открытые решения» должны быть закрыты до соответствующей итерации. Claude Code не должен заполнять юридические, финансовые и операционные пробелы предположениями.